

University of Petroleum and Energy Studies



Internship - High Level Design

SecuMetrics

Security Metrics and Reporting

BACHELOR OF TECHNOLOGY

CSE (Cyber Security and Forensics)

SUBMITTED BY

Aman Singh (R2142211023)

Ashutosh Mishra (R2142211055)

Hrishika Malla (R2142211059)

Rashmitha Deekonda (R2142211063)

Vaibhav Kumar(R2142211033)

GUIDED BY

Ms. Shamili Prabakaran

PROJECT TEAM MEMBERS:

S. No.	Name	SAP ID	E-mail	Phone number	Branch
1	Aman Singh	500096248	500096248@stu.upes.ac.in	8840971466	B.Tech CSE (CSF) Batch 3
2	Ashutosh Mishra	500096355	500096355@stu.upes.ac.in	6393770535	B.Tech CSE(CSF) Batch 4
3	Hrishika Malla	500096092	500096092@stu.upes.ac.in	8445288289	B.Tech CSE (CSF) Batch 3
4	Rashmitha Deekonda	500096310	500096310@stu.upes.ac.in	9553485911	B. Tech CSE (CSF) Batch 4
5	Vaibhav Kumar	500095277	500095277@stu.upes.ac.in	7983068806	B.Tech CSE(CSF) Batch3

Table of Contents

1. Introduction
 - 1.1. Scope of the document
 - 1.2. Intended audience
 - 1.3. System overview
2. System Design
 - 2.1 Application Design
 - 2.2 Process Flow
 - 2.3 Information Flow
 - 2.4 Components Design
 - 2.5 Key Design Consideration
 - 2.6 Api Catalogue
3. Data Design
 - 3.1 Data Model
 - 3.2 Data Access Mechanism
 - 3.3 Data Retention policies
 - 3.4 Data Migration
4. Interface
5. State and Session Management
6. chaching
7. Non-functional requirements
8. Reference

1. Introduction

Security metrics are tools designed to collect, analyze, and report relevant performance-related data, enabling organizations to measure the effectiveness of their IT security performance goals and objectives. By establishing a comprehensive security metrics and reporting framework, organizations can gain valuable insights into threats and risks,

identify areas for improvement, and optimize their security posture to maximize protection from threats.

1.1 Scope of the document

Defining key security metrics and key performance indicators (KPIs) to measure the effectiveness of IT security controls and risk management practices. Developing a reporting framework to present security metrics and KPIs to stakeholders. Establishing a process for regular review and analysis of security metrics and KPIs. Identifying tools and technologies to support the collection, analysis, and reporting of security metrics and KPIs.

1.2 Intended audience

The intended audience for the Security Metrics and Reporting includes:

1. Primary Audience

The IT security team will be responsible for collecting, analyzing, and reporting on security metrics and KPIs. They will use the security metrics and reporting framework to identify areas for improvement, optimize security controls, and provide insights to stakeholders.

2. Secondary Audience

The audit and compliance team will use the security metrics and reporting framework to ensure that the organization is meeting regulatory and compliance requirements, and to identify areas for improvement.

Business unit leaders will use the security metrics and reporting framework to understand the security risks associated with their business units, and to make informed decisions about resource allocation and risk management.

3. Tertiary Audience

The IT operations team will use the security metrics and reporting framework to understand the security implications of IT operations, and to identify areas for improvement.

The development team will use the security metrics and reporting framework to understand the security implications of software development, and to identify areas for improvement.

1.3 System overview

The Security Metrics and Reporting system is designed to provide a comprehensive framework for measuring, monitoring, and reporting on the effectiveness of our organization's IT security controls and risk management practices. The system will collect, analyze, and report on security metrics and key performance indicators (KPIs)

to provide insights into the organization's security posture and risk management practices.

System Components:- Data collection, Data Analysis, Reporting and Visualization
Integration and APIs System Architecture, System Flow, System Benefits.

2. System Design

The overall architecture and design of the security metrics and reporting system, including the components, interactions, and relationships between them. This includes the design of the database, application servers, web servers, and other infrastructure components.

1. **Application Design:** The design of the application layer of the security metrics and reporting system, including the user interface, business logic, and data access layers. This includes the design of the dashboards, reports, and other visualizations that provide insights into security metrics and trends.

- In a security metrics and reporting project, the application design would involve designing a user-friendly and intuitive interface that allows security analysts and stakeholders to easily access and analyze security metrics and reports.

2. **Process Flow:** The sequence of steps and activities involved in collecting, processing, and reporting security metrics and data. This includes the workflows and business processes involved in data ingestion, data processing, report generation, and alerting.

- In a security metrics and reporting project, the process flow would involve designing a workflow that automates the collection and processing of security data, generates reports and alerts, and notifies stakeholders of security incidents and trends.

3. **Information Flow:** The flow of data and information between different components and systems in the security metrics and reporting system. This includes the flow of data from security tools and systems, through the application and database layers, to the reporting and analytics components.

- In a security metrics and reporting project, the information flow would involve designing a data pipeline that collects and processes security data from various sources, stores it in a database, and makes it available for reporting and analytics.

4. **Components Design:** The design of individual components and modules within the security metrics and reporting system, such as data ingestion components, data processing components, report generation components, and alerting components.

- In a security metrics and reporting project, the components design would involve designing individual components that can be easily integrated and scaled to meet the needs of the system.

5. **Key Design Considerations:** The critical design factors and constraints that must be considered when designing the security metrics and reporting system, such as security, scalability, performance, and usability.

- In a security metrics and reporting project, the key design considerations would involve ensuring that the system is secure, scalable, and performant, while also providing a user-friendly and intuitive interface for security analysts and stakeholders.

6. API Catalogue: A collection of APIs and interfaces that provide access to the security metrics and reporting system, including APIs for data ingestion, report generation, and alerting.

- In a security metrics and reporting project, the API catalogue would involve designing a set of APIs and interfaces that allow security tools and systems to integrate with the system, and provide access to security metrics and reports.

3.Data Design

In the context of security metrics and reporting, data design refers to the process of defining the structure and organization of the data that will be collected, stored, and analyzed to support security metrics and reporting. This includes defining the data elements, data types, and relationships between data elements. A well-designed data structure is essential to ensure that the data is accurate, complete, and consistent, and that it can be easily analyzed and reported on.

3.1 Data Model: A data model is a conceptual representation of the data design. It describes the relationships between different data elements and how they are organized. In the context of security metrics and reporting, a data model might include entities such as:

- Security incidents
- Vulnerabilities
- Threats
- Assets
- Users

The data model should be designed to support the security metrics and reporting requirements, and should be flexible enough to accommodate changing requirements over time.

3.2 Data Access Mechanism: A data access mechanism refers to the way in which data is accessed and retrieved from the data store. In the context of security metrics and reporting, this might include:

- APIs (Application Programming Interfaces)
- Query languages (e.g. SQL)
- Data visualization tools
- Reporting tools

The data access mechanism should be designed to ensure that data is accessed securely, and that access is restricted to authorized personnel.

Data Retention Policies: Data retention policies define how long data is kept and when it is deleted or archived. In the context of security metrics and reporting, data retention policies are important to ensure that:

- Data is kept for a sufficient amount of time to support historical analysis and trending
- Data is deleted or archived when it is no longer needed, to reduce storage costs and minimize the risk of data breaches

Data retention policies should be designed to meet regulatory and compliance requirements, as well as business needs.

3.3 Data Migration: Data migration refers to the process of moving data from one system or data store to another. In the context of security metrics and reporting, data migration might be necessary when:

- Upgrading to a new security information and event management (SIEM) system
- Migrating to a cloud-based data store
- Integrating data from multiple sources into a single data store

Data migration should be done carefully to ensure that data is not lost or corrupted during the migration process, and that data integrity is maintained.

In summary, these terms are all related to the management of data in a security metrics and reporting project. They are important to ensure that data is accurate, complete, and consistent, and that it can be easily analyzed and reported on to support security decision-making.

4. Interface

The interface of a security metrics and reporting project is a critical component that enables users to interact with the system, view security metrics, and generate reports. The interface should be intuitive, user-friendly, and provide a clear and concise view of security-related data.

Components: The interface of a security metrics and reporting project typically includes the following components:

1. **Dashboard:** A dashboard is a centralized view of key security metrics and performance indicators (KPIs). It provides a quick and easy way to view security-related data and identify trends and anomalies.
2. **Navigation Menu:** A navigation menu allows users to access different sections of the interface, such as reports, metrics, and settings.
3. **Reports:** Reports provide detailed information on specific security-related topics, such as vulnerabilities, threats, and incidents. Reports can be generated in various formats, including PDF, CSV, and Excel.
4. **Metrics:** Metrics provide a quantitative view of security-related data, such as the number of vulnerabilities, threats, and incidents. Metrics can be displayed in various formats, including charts, graphs, and tables.
5. **Filters:** Filters allow users to narrow down data by specific criteria, such as date range, asset type, and severity level.

6. **Search:** A search function allows users to quickly find specific data within the system.
7. **Alerts:** Alerts notify users of critical security-related events, such as new vulnerabilities or incidents.
8. **Settings:** Settings allow users to customize the interface, such as setting up report schedules and configuring alert thresholds.

5. State and Session Management

State Management: State management refers to the process of managing the state of a user's interaction with the system. In a security metrics and reporting project, state management is critical to ensure that the system can track a user's progress and maintain their session across multiple requests.

Types of State: There are two types of state that need to be managed in a security metrics and reporting project:

1. **Session State:** Session state refers to the data that is stored on the server-side and is associated with a user's session. This can include data such as the user's username, role, and permissions.
2. **Application State:** Application state refers to the data that is stored on the client-side and is associated with the application. This can include data such as the current page, selected filters, and report settings.

Session Management: Session management refers to the process of managing a user's session across multiple requests. In a security metrics and reporting project, session management is critical to ensure that the system can track a user's progress and maintain their session.

Session Management Techniques: There are several session management techniques that can be used in a security metrics and reporting project, including:

1. **Cookie-based Session Management:** This technique uses cookies to store a user's session ID on the client-side. The session ID is then used to retrieve the user's session data from the server-side.
2. **Token-based Session Management:** This technique uses tokens to authenticate a user's requests. The token is generated on the server-side and is sent to the client-side, where it is stored in a cookie or local storage.
3. **Server-side Session Management:** This technique stores the user's session data on the server-side and uses a session ID to retrieve the data.

6. Caching

Caching is a technique used to improve the performance of a system by storing frequently accessed data in a faster, more accessible location. In a security metrics and reporting project,

caching can be used to store security-related data, such as metrics, reports, and dashboards, to reduce the load on the system and improve response times.

caching can be used to improve the performance of the system in several ways, including:

1. **Reducing Database Queries:** By caching security-related data, such as metrics and reports, the system can reduce the number of database queries, which can improve response times and reduce the load on the database.
2. **Improving Report Generation:** By caching report data, the system can improve the performance of report generation, which can reduce the time it takes to generate reports and improve the user experience.
3. **Enhancing Dashboard Performance:** By caching dashboard data, the system can improve the performance of the dashboard, which can reduce the time it takes to load the dashboard and improve the user experience.

7. Non-functional Requirement

1. Performance: The system should be able to handle a minimum of 100 concurrent users, with a response time of less than 2 seconds for dashboard loading and less than 5 seconds for report generation.

- Rationale: This requirement ensures that the system can handle a large number of users and provide a responsive user experience, even during peak usage periods.

2. Availability: The system should be available 99.99% of the time, with a maximum downtime of 1 hour per month for maintenance and upgrades.

- Rationale: This requirement ensures that the system is always available to users, with minimal downtime for maintenance and upgrades.

3. Security: The system should implement encryption for all data in transit and at rest, and should comply with relevant security standards and regulations, such as [GDPR](#) and [HIPAA](#).

- Rationale: This requirement ensures that the system protects sensitive security data and complies with relevant security standards and regulations.

4. Scalability: The system should be able to scale to handle an increase of 20% in user traffic within 3 months, without a decrease in performance.

- Rationale: This requirement ensures that the system can handle increased user traffic and scale to meet growing demands.

5. Usability: The system should provide an intuitive user interface, with clear and concise navigation and reporting, and should be accessible on a variety of devices and browsers.

- Rationale: This requirement ensures that the system is easy to use and provides a good user experience, even for users who are not familiar with security metrics and reporting.

6. Data Integrity: The system should ensure that all data is accurate, complete, and consistent, and should implement data validation and error handling mechanisms to prevent data corruption.

- Rationale: This requirement ensures that the system provides accurate and reliable security metrics and reporting, and prevents data corruption or loss.

7. Backup and Recovery: The system should implement automated backup and recovery processes, with a recovery time objective (RTO) of less than 1 hour and a recovery point objective (RPO) of less than 1 day.

- Rationale: This requirement ensures that the system can recover quickly and easily in the event of a failure or data loss, and minimizes the impact on users.

8. Compatibility: The system should be compatible with a variety of operating systems, browsers, and devices, including Windows, macOS, Linux, Chrome, Firefox, Safari, and mobile devices.

- Rationale: This requirement ensures that the system can be accessed and used by a wide range of users, regardless of their device or platform.

9. Maintainability: The system should be designed to be easily maintainable, with clear and concise documentation, and should allow for easy updates and patches.

- Rationale: This requirement ensures that the system can be easily maintained and updated, with minimal downtime and impact on users.

10. Auditing and Logging: The system should implement auditing and logging mechanisms, with clear and concise logs, and should provide real-time alerts and notifications for security incidents.

- Rationale: This requirement ensures that the system provides a clear and transparent audit trail, and allows for real-time monitoring and response to security incidents.

These non-functional requirements are critical to ensuring that the security metrics and reporting project meets the needs of its users and stakeholders, and provides a secure, reliable, and high-performing system.

8. Reference

L. Wang, T. Islam, T. Long, A. Singhal and S. Jajodia, "An Attack Graph Based Probabilistic Security Metrics", 22nd IFIP WG 11.3 Working Conference on Data and Application Security, July 2008.

D. Kleidermacher and M. Kleidermacher, Embedded Systems Security: Practical Methods for Safe and Secure Software and Systems Development, Newton, MA, USA:Newnes, 2012.

Kaiming He;Xiangyu Zhang;Shaoqing Ren;Jian Sun 2016 IEEE Conference on Computer Vision and Pattern Recognition (CVPR)



Innovation Center for Education



TRUSTED DELIVERY PARTNER for IBM ICE

Vladimir Marbukh 2023 IEEE 20th Consumer Communications & Networking Conference (CCNC)